Relatório de Atividade Prática

Utilização de GitHub Secrets em Pipelines CI/CD

1. Explicação do problema encontrado

O projeto inicial apresentava uma vulnerabilidade de segurança grave ao armazenar uma variável confidencial em texto limpo diretamente no arquivo de configuração do fluxo de trabalho (`.github/workflows/main.yml`). Essa prática expõe o dado a qualquer pessoa com acesso de leitura ao repositório e o mantém registrado permanentemente no histórico de controle de versão (Git), criando um risco significativo de vazamento de informações e acesso indevido.

2. Nome do Secret utilizado

MENSAGEM_SECRETA

3. Como o Secret chegou até a aplicação

O valor sensível foi primeiramente cadastrado e criptografado nas configurações do repositório no GitHub (Settings > Secrets and variables > Actions). Durante a execução da pipeline, o GitHub Actions acessou esse secret através da sintaxe `${{ secrets.MENSAGEM_SECRETA }}` e o injetou de forma segura no ambiente como uma variável de ambiente. Em seguida, a aplicação Node.js capturou esse valor dinamicamente utilizando o comando `process.env.MENSAGEM_SECRETA`, assegurando que o sistema recebesse a informação sem que ela precisasse ser escrita no código-fonte.

4. Respostas das Questões Propostas

Sobre a Situação Inicial:

- **Onde o segredo está armazenado?** Diretamente no código-fonte do repositório, dentro do arquivo de configuração da pipeline.
- **Quem poderia visualizar essa informação?** Qualquer pessoa com acesso de leitura ao repositório, bem como qualquer indivíduo navegando pelo histórico de commits.
- **Por que essa prática não é recomendada?** Pois o arquivo é versionado. A credencial ficará gravada no histórico para sempre, mesmo que o arquivo seja editado e apagado posteriormente.
- **O que poderia acontecer se essa informação fosse uma senha ou um token real?** Indivíduos não autorizados poderiam comprometer sistemas restritos, acessar dados privados, manipular bancos de dados ou utilizar a infraestrutura para fins maliciosos.

Sobre a Validação e Conceitos Finais:

- **Diferença entre armazenar no pipeline.yml e no GitHub Secrets:** No arquivo YAML, o valor fica exposto publicamente; no GitHub Secrets, ele é armazenado isoladamente de forma criptografada e é mascarado automaticamente nos registros (logs) de execução.
- **Onde o valor do Secret fica configurado?** Nas configurações de segurança da plataforma do GitHub, separadas dos arquivos do código da aplicação.
- **O valor do Secret deve ser colocado no código da aplicação?** Não. A aplicação deve apenas ler a informação externamente através de variáveis de ambiente.
- **Qual é a função de process.env.MENSAGEM_SECRETA?** É a instrução utilizada pelo Node.js para buscar no sistema o valor da variável de ambiente que foi injetada pela pipeline.
- **Por que utilizar Secrets é importante em uma pipeline de CI/CD?** Garante o isolamento de dados sensíveis, evita vazamentos acidentais e facilita a rotação de credenciais sem alterar o código do projeto.
- **Se fosse uma senha de banco de dados, por que seria inadequado colocar no .yml?** Qualquer usuário com acesso ao repositório ganharia controle total sobre o banco de dados de produção, comprometendo totalmente a integridade e privacidade da aplicação.

5. Evidência de Execução

Abaixo encontra-se a comprovação de que a pipeline foi configurada corretamente com o secret e executada com sucesso no ambiente do GitHub Actions.

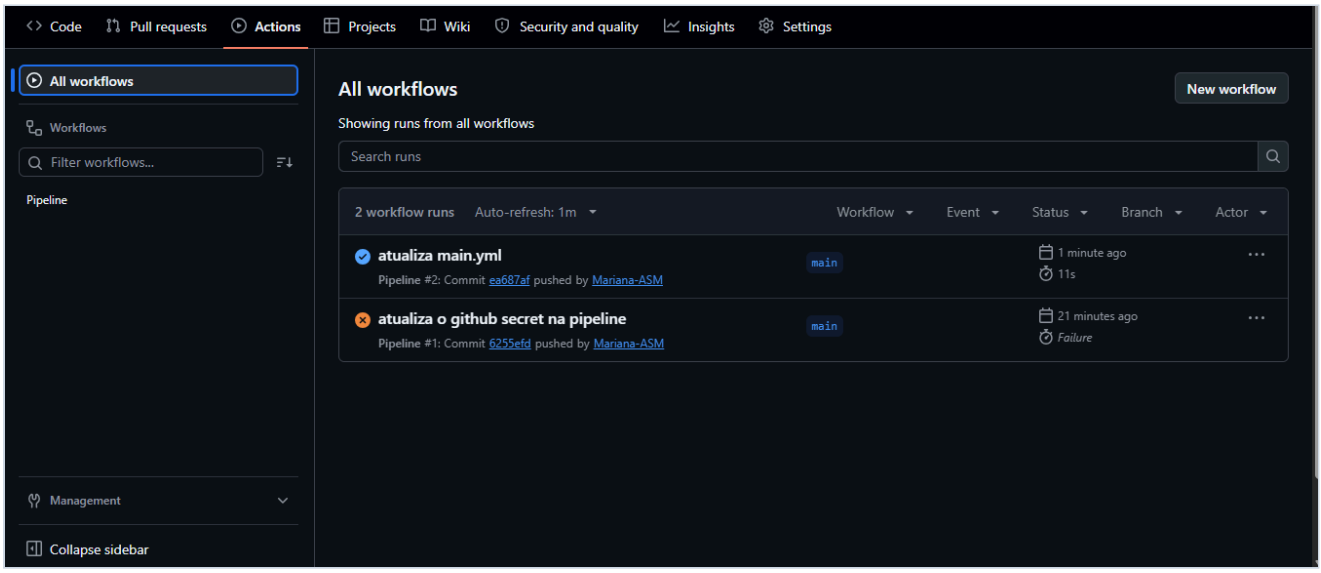


Figura 1: Pipeline executada com sucesso após a implementação do GitHub Secrets.

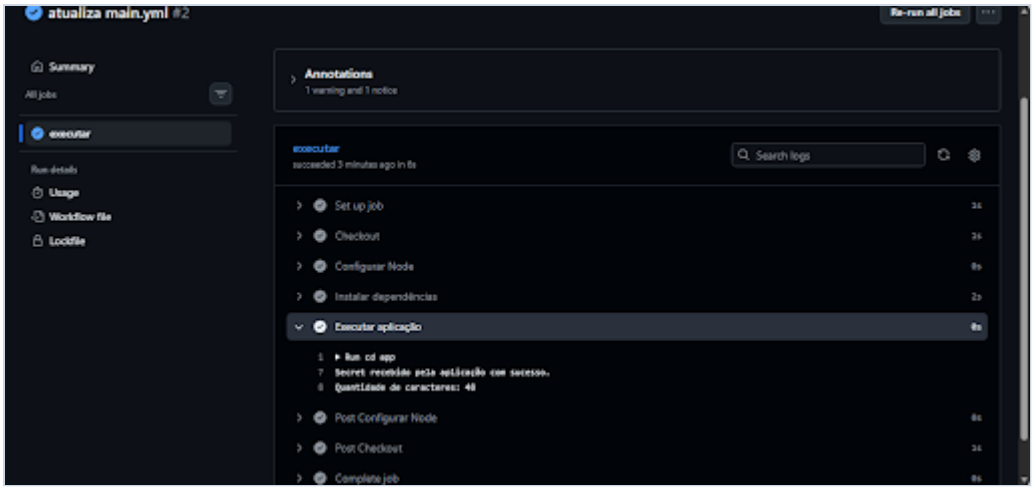


Figura 2: Logs da execução demonstrando que a aplicação recebeu a variável confidencial com sucesso sem expor o texto original.